

Comment Template for: NIST SP 800-157r1 (Final Public Draft)

Please submit responses to piv_comments@nist.gov by January 10, 2025

Organization: CertiPath Inc.
Name of Submitter/POC:
Email Address of Submitter/POC:

Comment #	Section	Page #	Line #	Comment (Include rationale for comment)	Suggested Change	
1		2.1	6	384	"The derived PIV credential life cycle consists of the activities described above: . . ." However, they are not "described," the description is the purpose of this section. At best, they are "identified" above.	Replace "described" with "identified" or similar verb.
2		2.1	6	394-398	Only the first sentence here is necessary. The other two sentences don't add any value. In addition, the first sentence should be modified to cite the PIV credential or "other Federal PKI digital credentials"	Revise the first sentence to draw it closer to the Federal PKI Common Policy. Delete the rest of the paragraph.
3		2.1	6	402	What is "invalidation"?	Recommend adding a reference to Section 2.4 here.
4		2.2	8	437-440	for trust of the credentials they issue and the devices on which they will reside. <i>All AAL3 derived PIV credentials SHALL only be issued to devices that the home agency has determined to have been issued to the cardholder.</i> " This appears to imply that the home agency owns the devices. Is this a fair assumption?	If AAL3 requires that the Home Agency "owns" or "sponsors the issuance of" the device that will hold an AAL3 credential, this should be made clear here.
5		2.2	8	443	"This <i>implies</i> that a third-party organization or service provider issuing derived PIV credentials needs to have access to the PIV identity account to meet this requirement." Use of the term "implies" is out of place in this document, particularly as Section 2 is 'normative'.	Recommend revising this sentence to indicate that home agencies must ensure controlled access to the PIV identity account for third party dPIV issuers. Could be directly or indirectly - but is certainly more than "implied".
6	2.2.3		10	510-511	"supervised remote identity proofing" is obsolete. New term is "remotely attended"	Recommend updating language to align with SP 800-63-4 by replacing "supervised remote" with "remotely attended"
7	2.2.3		10	512-515	This paragraph is misplaced. This section is about issuance of a dPIV in the absence of a PIV Card. This states that the dPIV should be issued when the PIV is issued.	Recommend moving this paragraph to the Section 2.2 Introductory language.
8				516-517	"Derived PIV credentials issued in this manner MAY also be enabled for physical access, as described in Appendix D." This is misleading. The dPIV credentials for PACS are completely different from those issued for logical access. You would not be "enabling" dPIV that was issued for smartcard logon for PACS access, for example.	Recommend revising this sentence as follows: "Derived PIV credentials intended for PACS use, as described in Appendix D, MAY also be issued in this manner."
9	3.2.3		16	690	Typographical error: ". . .the authenticator SHALL be reset and <i>will requires re-binding</i> to the PIV identity account, . . ."	Revise language for grammar.
10	C.1		29	1062	"does not easily accommodate" suggests that the PIV card form factor can be accommodated and where this is the case, it should be.	Recommend revising this statement to ". . .cannot accommodate. . ."
11	C.1		29	1066-1067	"if the issuance of a derived PIV credential has been approved, . . ." End of last paragraph said the request for issuance had been approved. Therefore, this is redundant.	Recommend removing this clause.
12	C.1		29	1072	". . .export of the public key to the IDMS, which generates the certificate. . ." Not strictly true. The IDMS does not generate the certificate per se.	Recommend revising this to "causes the certificate to be generated" or words to that effect.

13	C.1	29	1075-1077	Since the recipient is there in person at the security office, why do they need out of band confirmation of credential issuance?	Review this provision - is it correct for in person issuance of an AAL3 dPIV? If not remove it.
14	Appendix B & Appendix D			This section is confusing. Appendix B states that Derived PIV application has been deprecated (see Section B.1.1, lines 862-863). Appendix B then goes into great detail concerning use of the derived PIV application. The Appendix B construction is repeated in Appendix D with emphasis on cardAuth and SM-Auth, but there is no mention that the derived PIV application has been deprecated. In addition, if the PIV applet will be the new normal going forward, should both of these sections be revised to be inclusive - addressing both PIV app and dPIV app?	Consider revising Appendix B and D to be more forward looking. Also, be clearer concerning the status of dPIV app.